Beyond Zero:
Enterprise security for the AI era



Joseph Valente and Michal Zalewski

The rise of autonomous AI agents and the accelerating velocity of corporate data access are stretching the application-centric model of zero trust security to its breaking point. This article introduces Beyond Zero, a new security paradigm designed for the AI era. The Beyond Zero architecture performs per-resource access decisions for humans and agents at machine speed. By shrinking the trust boundary from the application level to individual action and by coupling static authorization guarantees with dynamic, AI-driven reasoning, Beyond Zero enables a selfdefending enterprise capable of mediating thousands of human and machine decisions per second. Google's vision for the future of this access model as well as a call for industry collaboration and standards development are outlined here.

Enterprise security is transitioning from human-speed security to high-frequency, AI-mediated defense. This new model is called Beyond Zero, and the fundamental concepts for the new architecture are laid out in this article. Beyond Zero allows for a contextual, risk-based, resourcelevel authorization model to run at machine speed, securing both humans and agents without overburdening users.

The Beyond Zero model has the following key features:

Resource/action-based security. Individual actions on individual resources are where authorization decisions are made, rather than provisioning access to a tool, application, or feature within an application. This is true no matter where those resources are accessible (e.g., via frontend tooling, API, MCP, or other access methods).

Blended static and dynamic security. Granular static policies are applied to resource accesses in addition to fully dynamic controls that apply even stronger security in risky or complex scenarios. This allows for dynamic controls to be applied without shifting to a fully dynamic security model that is challenging to statically verify.

Automatically enriched context. The decision systems can draw on context about the user, what the user should be working on, what data the user is trying to interact with, what the user is attempting to do with the data, and what potential risk mitigations are available. These facts are always available to the decision-making infrastructure.

Automated in-depth investigation. Investigations can be triggered to run autonomously by risk signals and, in turn, can activate either challenges or containments that are immediately applied to the user's stream of accesses.

Challenges and containments. Challenges and containments can be triggered directly from the security policies, enabling accessors to provide additional risk information on demand.

Beyond Zero builds on the BeyondCorp model Google introduced in 2014 by extending the zerotrust concept to the authentication and authorization layers. The assumptions underpinning BeyondCorp—that accessors are human, that actions occur at human speed, and that applications are the correct boundary for trust—are no longer sufficient. Now that we are entering an era where AI agents access data at 10 times the rate of humans, often reasoning about information across vast unstructured datasets, a new model is needed for securing data. Note that when *agents* are discussed in this article, that specifically refers to AI agents that mimic human behavior.

The publication of the BeyondCorp whitepaper[1] marked both a milestone on Google's own journey toward adopting the BeyondCorp model as well as a vision for how the rest of the industry could both adopt the same model and build the infrastructure to help others adopt a similar continuous authorization model. This article marks a milestone in Google's own effort to transition to the Beyond Zero model as well as a vision for where the industry needs to move to accelerate this transition.

The Problem: Securing Data at Machine Speed

A number of major shifts have made the transition to the Beyond Zero model necessary. In particular, some of the major changes we have observed are:

Agents driving exponential growth in access volume. The transition from a human-centric workforce to an agentic one has fundamentally altered the frequency of access requests. AI agents, whether operating autonomously or as "copilots" for human users, interact with corporate resources at a far higher rate than traditional human activity. The legacy infrastructure is strained by the need to authorize tens of millions of concurrent machine-driven actions per second.

Unprecedented data velocity and scale. It is not merely the frequency of access that has changed, but also the volume of data being consumed. Even before the adoption of agents, there was already an exponential growth in both the volume and sensitivity of data being accessed inside digital applications. Additionally, with agentic workflows, there is now a rise in aggregation and reasoning across vast unstructured datasets, leading to an even greater growth in the volume of data. This "geometric shock" to the system means that more sensitive intellectual property and user data are available to be accessed and acted upon than ever before. While AI enables this data to be processed and acted upon more quickly, any processing would happen at a velocity that outpaces manual oversight and after-the-fact security operations (SecOps) review.

Increasing sophistication of the threat landscape. In the current environment, even the least sophisticated attackers have weaponized AI to accelerate their tradecraft. These adversaries use LLMs to rewrite malicious code on demand, making static detection methodologies less

effective. Attackers can now afford to be patient, testing surfaces that were previously considered low value, using automated agentic methods. Furthermore, the rise of agentic infrastructure introduces new attack vectors, such as the exploitation of *ambient authority*, where an agent is granted the full, often overprovisioned permissions of its human user. This combination of machine-speed attacks and nondeterministic agent behavior creates a risk profile that requires a move toward dynamic, intent-based defense.

The Solution: Introducing the Beyond Zero Model

Beyond Zero shifts the trust boundary from the application to the action being performed on a piece of data in realtime—and from after-the-fact investigation to in-the-moment evaluation and containment. It augments BeyondCorp's foundational identity with a "brain" capable of reasoning about the context and intent of a specific request in realtime.

Implementing all the Beyond Zero features (see table 1) allows an enterprise to express highlevel security policies that naturally follow resources across the company and trickle down into individual enforcement actions. Enterprises can also build both static and dynamic policies that take in large amounts of data to make highly granular decisions while minimizing the degree to which human users are interrupted during their workday. This unblocks a variety of use cases including access abuse, intellectual property protection, and compliance. For accessors (humans and agents), the *access bubble* that controls their permissions dynamically flexes to be bigger or smaller depending on what they need to do in a given moment, reducing overprovisioning without impacting productivity.

Table 1.The Beyond Zero model

Feature	BeyondCorp (Legacy)	Beyond Zero (New)
		Individual Action/Resource
		Limits the boundary of trust to an individual piece of data because normal ACLs are too coarse-grained Machine Speed
		Increases velocity of checks because attackers are starting to operate this way, and we need to match their speed. Static and Dynamic (Infer & Interrupt)
		Static policies are insufficient to codify the dynamic nature of today's enterprises.
		Identity + Device + Behavior + Data Context

		A holistic view of user behavior matching or surpassing the capabilities of a human analyst
		Intent (User and Policy) / Simple Static Evaluation / User Intent + Agent Intent can be interpreted and checked to ensure alignment and limit prompt injection risks.
Trust Application / Boundary	Tool	
Decision Speed	Human Speed	
Type	Static Policy (Allow/Deny)	
Context Attributes	Identity + Device	
Feature	**BeyondCorp (Legacy)**	**Beyond Zero (New)**
		User Intent + Agent Intent can be an input in dynamic evaluation against Policy Intent. Activity Window (before + after Action)
Action Window	Action Only	Looking at an action in the context of the many operations that a user or agent has performed both before and after their action can give a more holistic picture of whether the action is legitimate. Near-realtime and integrated back into authorization
Investigation	After-the-Fact	AI allows us to run rapid investigations in minutes instead of days or hours, and act on the results of these investigations. Linked to Policy (e.g., risk of hijacking, trigger security key touch)
Challenges and Containments	Unlinked to Policy	Reduced disruption to legitimate accessors compared with traditional approvals, tailored hard challenges for malicious actors

Beyond Zero Architecture

Beyond Zero operates by applying policy decisions to individual resources rather than applications as a whole. Authorization is evaluated for a specific resource rather than a tool or

application. Policies are dynamically derived from reasoning decisions and immutable principles that govern access. When an action is performed on data, a set of checks is performed, taking into account various pieces of information about the accessor, the data being accessed, and the operation being performed to authorize the access.

We maintain static policies (the floor) to ensure baseline security and compliance. Layered on top is a dynamic reasoning engine (the ceiling) that observes behavior and applies friction (challenges) when an action deviates from established norms or carries high risk. There's a statically enforced baseline that makes sure that the agent doesn't deviate from a certain set of rules; then there's a dynamic component that allows for decision-making at a higher granularity.

The Beyond Zero architecture consists of four cooperating components, described next, that form a continuous feedback loop. These components are autonomous governance, event intake, reasoning engine, and challenge infrastructure.

Autonomous Governance: Building the Enterprise World Model

Before a decision can be made, the system must understand the terrain. In the same way that selfdriving cars rely on a world model to understand the physics and constraints of the world in which they operate, so too does there need to be an accurate enterprise world model to help decide how agents and humans can take actions on resources throughout the enterprise. Through integration with existing HR and project management warehouses and other sources of data that show who humans inside the company are and how their work relates to the company's assets, the autonomous governance component uses AI to generate and maintain a live enterprise world model with the following information:

Who—information about accessors (humans and agents), including their job function, role, seniority, controlling human (in the case of agents), etc. This information can be sourced from a variety of identity, HR, and other system-of-record databases.

Preprocessing ensures that unstructured data is converted into static attributes that can be used as part of authorization. For example, when a person works in a given team, the subject matter of the team and graph relationships of the team to other teams can be extracted from the organizational chart and other HR data, creating a set of attributes that can be used as part of security checks in both static and dynamic policies.

What—a semantic understanding of data sensitivity (confidentiality [e.g., confidential, public, crown jewels, etc.] and data type [e.g., user data]). This information is preprocessed by AI, allowing for resource understanding to be translated into an understandable structure. This could take the form of a semantic graph or a resource model (e.g., showing relationships between enterprise resources).

How—information about what accessors are tasked to work on and how they do their work, based on historical usage and sharing patterns, group membership, team membership,

assignments, etc. Preprocessing extracts the precise data around work assignments (for example, a user is currently working on an assignment that requires access to data belonging to customers A, B, and C only).

The need to make access decisions without adding undue latency to user requests means that much of the information needed to make access decisions must be accurately prepopulated and available at low latency at access time.

Preprocessing becomes critical because the strict latency budgets available at access time mean that inference tasks must be front-loaded to ensure that accurate attributes are available at access time.

The underlying principle here is to minimize the overhead of individual realtime access decisions by precomputing as much of the reasoning outputs as possible. This precomputed knowledge allows you to make high-fidelity determinations with precision, previously unattainable using conventional access-control tools.

Event Intake: Connecting to Agent and Human Activity

To reason about risk, the system needs high-fidelity visibility, not only into the immediate action that's under evaluation, but also into the broader context of user actions and enterprise patterns. To accomplish this, Beyond Zero can ingest streams of events from a variety of traditional, existing data sources, including:

Server side (access logs from corporate proxies and APIs; enterprise productivity apps, systemlevel server access, and other server-side sources). Some of these signals can be used at access time without event enrichment. Others require preprocessing to formulate attributes that are, in turn, used at access time or otherwise can be used for post-access analysis for post-access actions.

Client side (on-device signals indicating browser state, local file access, or process activity). This includes signals coming from standard data loss prevention (DLP) solutions and existing client security agents running on the endpoint as well as raw system logs. These signals cannot be used without preprocessing and typically are not useful other than in limited use cases (for example, post-access).

Agent activity (logs of prompt inputs, execution plans, tool invocations, and more by AI agents). For agentic access scenarios, these additional signals can be used to determine whether the agent's access reflects both the intention of the user as well as alignment with enterprise policy.

The vast majority of this information is not directly acted upon by the agent but is used to gradually build a better understanding of user behavior and to intercept actions once a certain risk threshold is exceeded.

The information is stored in both a hot cache populated with processed data for use in fast access-time policy evaluations and a larger long-term data store that stores the larger set of data for more detailed evaluation and preprocessing by different AI agents.

Reasoning Engine: Making Static and Dynamic Decisions

The reasoning engine is the heart of Beyond Zero. It is a hierarchical AI system distributed across central server-side components and endpoint agents that consumes information about accessors as well as recent access signals to answer a single question: In the context of what is known about the user and the resource, is this specific action safe? The reasoning engine, in a similar way to data-storage systems, is capable of both fast reasoning tailored for at-access-time evaluation and slower inference to do richer analysis on a set of actions.

Policy Evaluation (Fast) or Inference (Slow)

In faster configurations, the reasoning engine can perform granular attribute-based access control to determine, for example, if a person is accessing data belonging to a VIP user in one of the customer support tools or if a person is attempting a high-risk operation. These can be blocked at access time.

In slower configurations, more complex anomalies can be detected, such as a human user accessing 500 percent more files than their peer group. These can then be intervened with custom challenges or containments.

Decision

The reasoning engine outputs a verdict: allow, deny, or challenge. These decisions then factor into out-of-band risk evaluations, which then become attributes that can be referenced in subsequent evaluations (even across attempts to access other applications or resources).

Attacker Scenarios

The curious contractor.

An external party attempts to compromise an enterprise by purchasing the stolen credentials of one of their contractors who is working on software development. As soon as the external attacker attempts to use the credentials to start their attack, they are seen trying to access data not linked to the contractor’s scope of work, and various challenges can be issued to the accessor to confirm the access is legitimate.

In this scenario, various aspects of the contractor's status are stored as risk attributes, and the contractor's position in the organizational chart, along with their typical scope of work, is stored as a set of attributes linked to the accessor's identity. The autonomous governance system has also performed analysis on the documents, understanding their semantic context.

At access time, the reasoning engine sees that a high-risk accessor with low subject-matter crossover is attempting to access sensitive documents. The contractor is given the option of requesting access via a document owner approval challenge (for an explanation of how this works, see "Challenge Infrastructure: Managing Exceptions" later in this article).

The suddenly foolish administrator.

In this scenario, a system administrator logs into a service as usual, but in another window is looking up basic questions about the architecture of the system—information that would be obvious to anyone experienced at the company. These signals are placed in long-term storage but are then processed into an attribute indicating potential risk.

The administrator then attempts a host of operations, all of which appear in rapid succession indicating usage of agentic assistance. The short-term reasoning engine sees the risk indicator attribute and the high-risk operation attribute and stops the operation, challenging the user to touch their security key and provide their password, preventing compromise. After clearing the challenge, the record is placed in long-term storage for evaluation again should an unusual operation be seen in the future.

Automated Reasoning

As Beyond Zero implementations mature, the reasoning engine could be used to reduce the burden of certain security controls by deciding that users don't need to be challenged in scenarios that are deemed low risk. Example: Security key touches might be seen as unnecessary if an accessor is the same person showing up at the same hour in the same location, but could then be reapplied should behavior start to deviate from the expected baseline.

Challenge Infrastructure: Managing Exceptions

Challenge infrastructure is used to either gather context using challenges or restrict access using containments. *Challenges* are introduced to gather further context before deciding whether to grant access. *Containments* are more durable "stop signs" that are designed to introduce substantial friction to an accessor's access in order to stop attacks. Containments are designed to

be dynamic and to move up or down in strength should a completed challenge clarify that the detected risk was a false positive.

Challenges

When the reasoning engine detects ambiguity or elevated risk, it triggers a challenge. Unlike the blunt "access denied" of the past, challenges are granular and context-aware:

Justification. "Please explain why you need access to this file."

Verification. "Touch your security key to prove you are present."

Approval. "Requesting manager approval for bulk export."

Biometric. "Please perform a selfie check to prove you're sitting at your machine."

Challenges are designed to be statically verifiable using policy; however, some challenges might contain dynamic evaluations that can then be statically evaluated. For example, policy can be written requiring a selfie check before an administrator is allowed to perform a high-risk action to ensure that they are sitting at their computer when the action is being performed (and have not lost or sold their credentials).

More dynamic checks are also possible. For example, a person attempting to email data to their personal account might be asked to provide a justification that can be checked against the document contents in realtime.

The goal of the challenge infrastructure is to abstract away the complexity of implementing each of these challenges into a single service that has static and dynamic policies written against it. That decoupling ensures that it can independently evolve as better challenges become available. For example, should a company roll out a fingerprint-enabled security key? This could be easily done.

Containments

Containments are a second, more durable type of interruption. These interruptions revoke some or all of the actor's access in response to a perceived risk. Containment revocation is generally not as straightforward as challenge completion. While some containments can be revoked by correctly passing a challenge, other containments might be lifted only when the security team interviews the contained user and their manager before deciding on a course of action.

An End-to-End Example: The "Rogue" Agent

Consider a scenario where an internal AI agent, SalesGenie, is authorized to read sales reports.

Action

SalesGenie attempts to query a highly sensitive strategic planning document inside Google Drive.

BeyondCorp Check

Both the agent and the person who prompted the agent have a valid certificate from an authorized machine and identity, and both identities are authorized to access sales reports. Access allowed.

Beyond Zero Check

Accessor context.

The reasoning engine sees that the user that prompted SalesGenie works only on financial services accounts in the Northeast. The user's risk score is also higher, as they have been recently attempting accesses that are not closely related to their work assignment.

Data context.

The data being accessed is highly strategic, company-level data used only in financial reporting. The only teams that typically access this data are the strategy and finance teams. The data is classified as highly confidential, the highest tier of sensitivity, as it could be used in insider trading.

Decision.

The reasoning engine finds a policy specifying that for data classified as highly confidential, a valid work assignment must be present. As the work assignment here does not match the worker types who need access to this data, the accessor is served two challenges. A second, slower inference can happen over the actor's recent accesses once the first risky action has been detected. This can lead to intervention once the detailed analysis has been performed by the automated reasoning engine. In this case, the inference might detect a pattern of accesses

together with logs showing the actor attempting to exfiltrate some of their data and decide that a stronger containment is needed.

Intervention.

(1) The human actor must confirm that the access the agent is attempting is intended by the human to minimize the risk of rogue actions by the agent. (2) The human actor must then request approval from the team that owns the data, confirming that they require access to it. (3) Following the failure to clear challenges and a more detailed inference completing over a larger set of actions, the user is then contained. In the vast majority of cases, the decision to contain will be autonomous. Only a tiny percentage would be escalated to human review when there is a high confidence in malicious intent, which is substantially higher fidelity than the current paradigm.

Accelerating Toward Beyond Zero in the Technology Industry

A shift toward a Beyond Zero model will require more broadly landing a number of major alignments across the industry. These would be useful areas for exploration:

Open architectures that can enhance transparency into access as enterprises make the agentic transformation—for example, standardized APIs for agent introspection, with a standardized way to analyze chain-of-thought/tool use in realtime.

Standards for agentic identities and how to define and control their access—for example, an industry standard for request annotations to make all agent actions attributable to a specific agent, a specific controlling user, and a specific task.

Frameworks for allowing reasoning engines to safely make access decisions and take actions—for example, make external, enterprise-operated policy evaluation and decision-point integration and enforcement a first-class citizen for all software-as-a-service products.

The National Institute of Standards and Technology (NIST) has already commenced an agent security effort, and, hopefully, efforts like this will accelerate the industry's path toward making these important standardizations.

Conclusion

The application boundary model is reaching its end of life as the rise of autonomous agents and exponential data velocity stretch legacy zero-trust frameworks to their breaking point. As AI agents join the workforce and the speed of business accelerates, what is needed is a security model that works at machine speed as well.

Beyond Zero represents the next major evolution in enterprise defense, shifting the trust boundary from the broad application level to the individual action performed on a specific resource. By unifying static authorization with a dynamic, AI-driven reasoning engine, the architecture allows a self-defending enterprise capable of mediating thousands of decisions per second at machine speed. It effectively fuses access management and security operations into a single, high-frequency feedback loop that can infer and interrupt threats in realtime.

Beyond Zero is the future of enterprise security, moving toward a model of security as an immune system that continuously adapts to the context and intent of every request. This transition is a strategic necessity for the agentic era, ensuring that enterprise data remains secure even as the boundaries between human and machine actions continue to blur. The hope is not only that these ideas will help make the industry safer, but also that others will build on this foundation to strengthen the state of the art of how security should work in this new era. Now that this future is coming into view, it's time to accelerate our investments toward the development of new standards, particularly around pluggable policy evaluations and agent context annotations.

As we continue our own journey in developing and deploying Beyond Zero, we intend to continue publishing more articles in this space. We encourage others to start the same journey and share their learnings with the industry as we all work through the challenges of this new era together.

Acknowledgments

The Beyond Zero approach is the culmination of years of thinking and work by many individuals at Alphabet and in the broader industry. In alphabetical order, we would like to thank Heather Adkins, Will Beers, Betsy Beyer, Darren Bilby, Gordon Chaffee, Garrett Cronin, Four Flynn. Ian Green, Eric Grosse, Royal Hansen, Sebastian Harris, Gregory Kick, Kaan Kivilcim, Bryan Landsiedel, Naveed Makhani, Justin McWilliams, Pankaj Rohatgi, Ismail Sebe, Ruchi Shah, Umesh Shankar, Nic Shupe, Adam Tanana, Marianna Tishchenko, Tavish Vaidya, Juan Vasquez, Rory Ward, Ollie Wild.

References

1 Ward, R. and Beyer, B. BeyondCorp: a new approach to enterprise security. *login* 39, 6 (2014), 6–11; https://www.usenix.org/publications/login/dec14/ward.

Related Material

From Zero to One Hundred
Demystifying zero trust and its implications on enterprise people, process, and technology
Matthew Bush, Atefeh Mashatan https://queue.acm.org/detail.cfm?id=3561799

Everything VPN is New Again
The 24-year-old security model has found a second wind.
David Crawshaw
https://queue.acm.org/detail.cfm?id=3439745

Developer Ecosystems for Software Safety
Continuous assurance at scale
Christoph Kern
https://queue.acm.org/detail.cfm?id=3648601

Joseph Valente *is a director of product management leading enterprise security efforts within Alphabet Security. While his current work focuses on securing all of Alphabet's business units—from Google Ads to DeepMind, YouTube, Devices, and Cloud—his previous roles inside Alphabet focused on creating what is now known as Sovereign Cloud from Google, Google Cloud's sovereign compute offering. Prior to Google, he cofounded the companies Pathify and Ebla, as well as working briefly as a consultant at Bain & Company. Contact him at josephvalente@google.com.*

Michal Zalewski *is a Distinguished Engineer at Google, leading Alphabet Security's strategy. Prior to rejoining Google he was chief information security officer at Snap, where he joined after more than a decade at Google. In his first Google stint, he was the director of information security and engineering and oversaw an organization of more than 100 engineers, growing these efforts through the company's initial early period of growth and establishing early means of*

solving for code vulnerabilities and product security challenges, as well as running design reviews and offensive security exercises for the company. Outside of Google, he writes at Substack and is the author of The Secret Life of Circuits. *Contact him at lcamtuf@google.com*.

Copyright © 2026 Held by Owner/Author. Publication rights licensed to ACM. This work is licensed under a Creative Commons Attribution International 4.0License.